

SİSTEMLER: SALDIRI VEKTÖRLERİ

[Kaynak](#)

İÇERİK

1. Sistem Güvenliği ve Altyapı Temelleri (System Security Fundamentals)
2. Sistemlere Yönelik Saldırı Vektörleri ve İlk Erişim (Attacks on Systems)
3. Yazılım Zafiyetleri ve Zafiyet Yönetimi (Vulnerabilities)
4. Sistem Yanlış Yapılandırmaları (Misconfigurations)

Sistem Güvenliği ve Altyapı Temelleri (System Security Fundamentals)

İnsan Faktörü vs. Altyapı Zafiyetleri: Güvenlikte En Zayıf Halka Yanılgısı

Siber güvenlikte savunma mimarisini kurgularken sıklıkla düşülen en büyük yanılgılardan biri, yalnızca uç nokta (endpoint) ve kullanıcı farkındalığına odaklanmaktır. Bir ağın güvenliğini, kapısında son derece eğitimli bir muhafızın beklediği bir kaleye benzetebiliriz. Bu muhafız (kullanıcı), **Phishing** (Oltalama - kullanıcıları aldatarak hassas bilgi veya yetki elde etmeye yönelik sosyal mühendislik saldırısı) veya **Deepfake** (Yapay zeka destekli, gerçeğinden ayırt edilemeyen sahte medya içerikleri) gibi modern manipülasyon tekniklerini tanıyıp savuşturabilecek kapasitede olabilir.

Ancak arka planda yatan mantıksal gerçek şudur: Eğer ana kapının kilidi (sistemin kendisi) zayıf, yamalanmamış veya yanlış yapılandırılmışsa, tehdit aktörleri muhafızla (kullanıcıyla) hiç muhatap olmadan doğrudan altyapıya sızabilirler.

DİKKAT: Siber saldırganlar her zaman en az direnç gösteren yolu (path of least resistance) seçerler. Kullanıcı etkileşimi gerektiren bir **Client-Side Attack** (İstemci taraflı saldırı) düzenlemek yerine, zafiyet barındıran bir servise **Direct Attack** (Doğrudan saldırı) gerçekleştirerek sisteme sessizce ve kullanıcıların haberi dahi olmadan arka kapıdan sızmayı tercih ederler. Bu durum, sistemin kendi mimari güvenliğinin (System Hardening), personel eğitiminden bağımsız olarak kusursuz olmak zorunda olduğunu kanıtlar.

Sistem Tanımı ve Etki Ölçeği (Scale of Impact)

Kredi kartı verileri, kurumsal e-postalar veya kritik veritabanları boşlukta durmaz; fiziksel veya sanal bir "sistem" üzerinde barındırılırlar. Teknik bağlamda bir sistem şunlar olabilir:

- **Fiziksel Sunucu (Physical Server):** Kurumun kendi veri merkezinde (On-Premise) barındırılan donanımlar.

- **Sanal Makine (Virtual Machine - VM):** Hipervizörler üzerinde koşan ve kaynakları izole edilmiş işletim sistemleri.
- **Bulut Platformu (Cloud Platform):** Microsoft 365, AWS veya Azure gibi, verinin ve altyapının üçüncü parti servis sağlayıcıları tarafından dağıtık mimaride tutulduğu yapılar.

Buradaki kritik teknik derinlik, saldırının **Etki Ölçeği (Scale of Impact)** ile ilgilidir. Bir saldırgan **Phishing** yoluyla sıradan bir çalışanın cihazını ele geçirdiğinde, etki alanı yalnızca o kullanıcının erişim yetkileriyle ve yerel dosyalarıyla sınırlıdır. Ancak saldırgan doğrudan bir **Mail Sunucusuna** (Örn: Microsoft Exchange Server) zafiyet sömürsü (Exploitation) yoluyla sızarsa, hiyerarşiyi tamamen atlayarak ağdaki binlerce kullanıcının posta kutusuna tek bir hamlede, en üst yetkiyle (System/Root) hükmeder.

Tehdit Modellemesi: Hedef Sistemlerin Saldırı Değeri (Attack Value)

Siber güvenlikte her hedefin tehdit aktörü gözündeki "Saldırı Değeri", sistemin barındırdığı verinin kritikliği ve ağ içindeki konumuyla doğrudan orantılıdır. Aşağıda farklı sistem profillerinin olası sızıntı senaryolarındaki teknik ve mantıksal sonuçları analiz edilmiştir:

1. Sıradan Bir Kullanıcı/Öğrenci Bilgisayarı: Bireysel bir cihazın ele geçirilmesi ilk bakışta düşük riskli görünse de, saldırganlar bu sistemleri genelde kişisel hesapları (Örn: Steam, oyun profilleri veya tarayıcıya kayıtlı şifreler) çalmak için kullanır. Daha da önemlisi, bu cihaz arka planda bir **Botnet'e** (Zombi bilgisayar ağı - genellikle geniş çaplı DDoS saldırıları düzenlemek için kullanılan, ele geçirilmiş cihazlar kümesi) dahil edilerek küresel bir saldırı altyapısının parçası haline getirilir.

2. Kıdemli BT Yöneticisi (IT Admin) Bilgisayarı: Bu sistem bir altın madenidir. Bir IT yöneticisinin cihazı ele geçirildiğinde, saldırganın asıl amacı o cihazdaki yerel veriler değil, cihazın sahip olduğu **Yüksek Ayrıcalıklardır (High Privileges)**. Saldırgan bu cihazı bir sıçrama tahtası (Pivot Point) olarak kullanarak **Yanal Hareket (Lateral Movement)** gerçekleştirir ve doğrudan bankanın, kurumun iç ağlarına, **Domain Controller** veya kritik veritabanlarına kalıcı erişim (Persistence) sağlar.

3. Hukuk Bürosuna Ait Posta Sunucusu (Mail Server): Gizliliğin (Confidentiality) en üst düzeyde olması gereken bu sistemlerin ihlali, genellikle **Data Exfiltration** (Veri sızdırma) ile sonuçlanır. Saldırgan, tüm posta kutularının dökümünü (Dump) alarak müşteri sırlarını, dava dosyalarını ve finansal anlaşmaları ele geçirir. Bu senaryodaki nihai amaç genellikle firmaya yönelik yüksek meblağlı bir **Şantaj (Blackmail/Extortion)** operasyonudur.

4. Endüstriyel Ağın (ICS/SCADA) Merkezindeki Bir Sunucu: Üretim tesisleri, enerji santralleri veya fabrikaların kalbindeki sistemler ele geçirildiğinde, saldırganın hedefi genellikle veriyi çalmaktan ziyade sistemin erişilebilirliğini (Availability) yok etmektir. Ağın tamamı **Ransomware** (Fidye Yazılımı - verileri güçlü kriptografik algoritmalarla şifreleyerek erişilemez hale getiren ve açmak için fidye talep eden zararlı yazılım) ile şifrelenir.

Endüstriyel duruşun maliyeti saniyede binlerce dolar olabileceğinden, mağdurun fidyeyi ödeme ihtimali çok yüksektir.

5. Kamu/Devlet Web Sitesi Yönetim Paneli: Bu tür bir sistemin ihlali genellikle finansal motivasyonlardan ziyade ideolojik veya politik amaçlar taşır. İhlal edilen sistem üzerinde **Defacement** (Web sitesinin arayüzünü yetkisiz bir şekilde değiştirme, genellikle propaganda mesajları veya saldırganın logosunu yerleştirme işlemi) uygulanarak Hacktivism (Hacktivism) eylemleri gerçekleştirilir. Amaç, kurumun itibarını (Reputation) zedelemek ve halk nezdinde güvensizlik yaratmaktır.

ÖNEMLİ: Tüm bu senaryoların bize anlattığı temel felsefe şudur: Mavi Takım (Blue Team) olarak savunma yaparken, her bir sistemin "Ele geçirilirse en kötü senaryo (Worst-Case Scenario) ne olur?" sorusuna göre sınıflandırılması ve **Defense in Depth** (Derinlemesine Savunma - tek bir güvenlik katmanının aşılmasına karşılık arka arkaya dizilmiş çoklu güvenlik kontrolleri) mimarisiyle korunması şarttır. Ana kapının kilidi kırıldığında, içeride saldırganı yavaşlatacak iç kapılar, segmentasyonlar ve alarm mekanizmaları (IDS/IPS) her zaman devrede olmalıdır.

Sistemlere Yönelik Saldırı Vektörleri ve İlk Erişim (Attacks on Systems)

Gelişmiş siber saldırılarda (APT - Advanced Persistent Threat vb.), nihai amaç ister verileri sızdırmak (Data Exfiltration), ister ağı **Ransomware** (Fidye yazılımı) ile kilitlemek, isterse de kurtarılamayacak şekilde sistemleri yok etmek (Wiper malware) olsun; operasyonun anatomisinde değişmeyen tek bir başlangıç noktası vardır: **Initial Access** (İlk Erişim - hedefin sistemine veya ağına yetkisiz bir ayak basma noktası elde etme aşaması).

Saldırganlar bu ilk erişimi sağlamak için genellikle üç ana vektöre odaklanırlar. Her bir vektörün arka plandaki çalışma mantığı, savunma zorlukları ve teknik dinamikleri aşağıda derinlemesine analiz edilmiştir.

İnsan Kaynaklı Saldırıları (Human-Led Attacks) ve Operasyonel Güvenlik Zafiyetleri

Bir ağın çevresel güvenlik cihazları (Firewall, IPS/IDS) ne kadar sağlam yapılandırılmış olursa olsun, sistem kullanıcıları her zaman en zayıf halkadır. Tehdit aktörleri karmaşık zafiyetleri sömürmek yerine genellikle doğrudan insan psikolojisini veya dikkatsizliğini hedef alır.

Bu vektör temel olarak şu şekillerde karşımıza çıkar:

- **Fiziksel Medya İstismarı:** Sokakta veya otoparkta bilerek bırakılan zararlı bir USB belleğin sisteme takılması. Bu cihazlar genellikle standart bir depolama birimi değil, **HID Spoofing** (İnsan Arayüz Cihazı taklidi) yapan donanımlardır (Örn: USB Rubber Ducky). Sisteme takıldığı anda kendini klavye olarak tanıtır ve milisaniyeler içinde zararlı komutlar

(Payload) çalıştırarak **Reverse Shell** (Ters bağlantı - hedef sistemden saldırganın makinesine açılan, komut yürütmeye yarayan bağlantı) alırlar.

- **Korsan (Pirated) Yazılımlar:** Güvenilmeyen kaynaklardan indirilen yazılımların içine gömülmüş **Trojan** (Truva Atı) varyantları, kullanıcı tarafından kendi elleriyle, üstelik genellikle yönetici (Admin) yetkileriyle çalıştırılır.
- **Kimlik Bilgisi Zafiyetleri (Credential Compromise):** İstatistiksel olarak veri ihlallerinin %81'i, çalınmış veya kırılmış parolalardan kaynaklanmaktadır. Kullanıcıların zayıf parolalar seçmesi veya aynı parolayı birden fazla platformda kullanması, saldırganların **Credential Stuffing** (Kimlik bilgisi doldurma - daha önce sızdırılmış kullanıcı adı/parola listelerini otomatik araçlarla farklı servislere deneme) saldırılarını mutlak başarıya ulaştırır.

Yazılım Zafiyetleri (Vulnerabilities) ve Mimari Yapılandırma Hataları

Her yazılım, doğası gereği mantıksal veya hafıza yönetimi tabanlı güvenlik kusurları (Security Flaws) barındırabilir. Sadece 2024 yılı içerisinde **40.000'den fazla** yazılım zafiyeti (CVE - Common Vulnerabilities and Exposures) yayınlanmış ve bunların **300'den fazlası** majör siber saldırılarda aktif olarak sömürülmüştür (Exploitation).

Bu zafiyetler genellikle yamanmamış (Unpatched) sistemlerde bulunur ve saldırganlara **RCE** (Remote Code Execution - Uzaktan Kod Çalıştırma) imkanı tanır. Ancak risk sadece yazılım hatalarıyla sınırlı değildir. Bilgi Teknolojileri (IT) yöneticilerinin kendi elleriyle yarattığı zafiyetler (Misconfigurations), tehdit aktörleri için çok daha caziptir.

ÖNEMLİ: IT yöneticilerinin sistemlere kısıtlamasız erişim (Unrestricted Access) tanımlaması veya kritik servislerde (Örn: RDP, SSH, Veritabanları) zayıf/varsayılan (Default) parolalar kullanması, saldırganın karmaşık bir **Exploit** (Zafiyet sömürü kodu) yazmasına gerek bırakmadan, meşru bir kullanıcı gibi doğrudan iç ağa sızmasını sağlar. Bu durum, **PoLP** (Principle of Least Privilege - En Az Ayrıcalık Prensibi) mimarisinin ihlal edilmesinin doğrudan bir sonucudur.

Tedarik Zinciri Saldırıları (Supply Chain Attacks): Sessiz ve Yıkıcı Tehdit

Modern sistemlerde bilgisayarınız veya sunucunuz izole bir ada değildir. Web tarayıcılarından geliştirme ortamlarına, mesajlaşma uygulamalarından animasyon kütüphanelerine kadar her yazılım, binlerce farklı açık kaynaklı veya üçüncü parti kütüphaneye (Library/Dependency) bağımlıdır.

Tedarik zinciri saldırısının teknik mantığı dehşet vericidir: Tehdit aktörü, hedefin kendisine doğrudan saldırmak yerine, hedefin kullandığı güvenilir bir yazılımın üreticisini (veya kullandığı bir kütüphanenin kod deposunu) hackler. Geliştirici firmanın güncelleme sunucusuna (CI/CD Pipeline) sızarak, yazılımın bir sonraki resmi güncellemesinin içine kendi zararlı kodunu gömer.

Sonuç olarak, binlerce kurumun sistemleri bu "meşru ve imzalı" güncellemeyi indirip kurduğunda, tüm ağlar eşzamanlı olarak ele geçirilmiş olur.

- **Tarihsel Bağlam (Vaka Analizleri):**

- **SolarWinds:** IT izleme ve yönetim yazılımı olan Orion'un güncelleme mekanizması hacklendi. Dünyadaki en kritik kamu ve özel sektör ağlarına, tamamen güvenilir görünen bir güncelleme üzerinden sızıldı.
- **3CX:** Popüler bir masaüstü VoIP istemcisinin enfekte edilmesiyle gerçekleşen ve binlerce şirketi etkileyen zincirleme bir saldırıdır.
- **TryHackMe Lottie Player Vakası:** TryHackMe platformu dahi, odalardaki animasyonları oynatmak için kullandığı üçüncü parti bir kütüphane olan Lottie Player üzerinden bir tedarik zinciri saldırısının kurbanı olmuştur.

DİKKAT: Bir **SOC (Security Operations Center)** analisti olarak tedarik zinciri saldırılarına karşı korunmanın en zor yanının, zararlı aktivitenin *güvenilen, izin verilen ve dijital olarak imzalanmış* bir süreçten gelmesi olduğunu bilmelisiniz. Antivirüsler imzalı yazılımları genellikle taramadan geçirir. Bu noktada koruma, imza tabanlı (Signature-based) yaklaşımdan ziyade **Davranışsal Analiz (Behavioral Analysis)** gerektirir.

Bunu bir SOC ortamında nasıl yakalayacağımızı teknik bir log üzerinden örneklendirelim:

```
EventID: 3
Source: Microsoft-Windows-Sysmon
Task Category: Network connection detected
UtcTime: 2026-05-06 23:14:05.123
ProcessGuid: {A1B2C3D4-5678-90EF-1234-567890ABCDEF}
ProcessId: 4512
Image: C:\Program Files\TrustedApp\trusted_updater.exe
User: NT AUTHORITY\SYSTEM
Protocol: tcp
Initiated: true
SourceIp: 192.168.1.50
SourcePort: 54321
DestinationIp: 185.15.22.10 (Known Malicious C2 Server)
DestinationPort: 443
```

Log Çıktısının Teknik Analizi ve SOC Perspektifi:

- **Image:** C:\Program Files\TrustedApp\trusted_updater.exe . Normal şartlarda bu uygulama (örneğin SolarWinds veya 3CX) kurum içinde çalışmasına izin verilen meşru bir yazılımdır. Geleneksel bir Antivirüs bu süreci engellemez.
- **User:** NT AUTHORITY\SYSTEM : Bu süreç sistemdeki en yüksek ayrıcalıklarla çalışmaktadır. Saldırganın bu süreç üzerinden edindiği yetki, ağda tam kontrol (Domain Dominance) sağlamasına kapı aralar.
- **DestinationIp & Port:** Analist olarak sormamız gereken soru şudur: "Neden kurum içi bir izleme aracının veya animasyon kütüphanesinin güncelleme servisi, daha önce hiç

iletiřim kurmadıęı, kategorize edilmemiř ve istihbarat listelerinde řüpheli grnen (veya maskelenmiř) bir IP adresine (185.15.22.10) 443 (HTTPS) portu zerinden dıřarıya doęru (Initiated: true) bir baęlantı bařlatıyor?"

İřte tedarik zinciri saldırılarına karřı koyabilmenin yegane yolu; meřru srelerin oluřturduęu anomali aę trafiklerini (Beaconing, C2 Communication) veya bu srelerin beklemedięimiz alt sreler (Child Processes - rn: Gvenilir uygulamanın aniden `cmd.exe` veya `powershell.exe` aęırması) bařlatmasını **Tehdit Avcılıęı (Threat Hunting)** pratikleriyle tespit edebilmektir.

Yazılım Zafiyetleri ve Zafiyet Ynetimi (Vulnerabilities)

Yazılım Zafiyetlerinin Doęası ve Tarihsel Gecikmeler (Software Vulnerabilities)

Siber gvenlikte kabul edilmesi gereken en temel mimari gerek řudur: Geliřtirilen her yazılım, doęası gereęi mantıksal hatalar, bellek ynetimi kusurları veya eksik girdi doęrulama (input validation) sorunları barındırır. Bir zafiyetin koda eklenmesi ile keřfedilmesi arasında bazen on yıllar srebilen bir bořluk olabilir.

Bunun en arpıcı rneęi **Shellshock** (Bash ortam deęiřkenleri zerinden uzaktan kod alıřtırmaya olanak tanıyan kritik Linux zafiyeti) vakasıdır. 1992 yılında Bash kaynak koduna giren bu hata, tam 22 yıl boyunca sistemlerde gizli kalmıř ve ancak 2014 yılında keřfedilebilmiřtir. Bu durum, siber gvenlikte "bilinmeyen bilinmeyenler" (unknown unknowns) konseptinin ne kadar tehlikeli olduęunu kanıtlar.

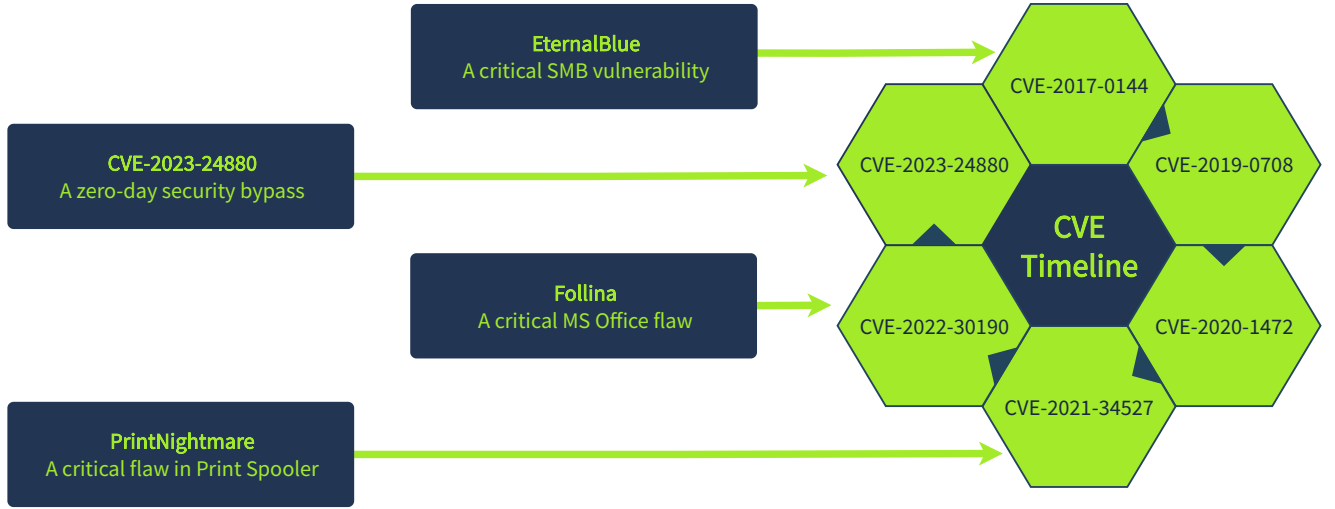
NEMLİ: En kt durum senaryosu (worst-case scenario), bir sistemdeki zafiyetin savunmacılardan ve yazılım reticisinden nce tehdit aktrleri (saldırganlar) tarafından keřfedilmesidir. Bu duruma **Zero-day** (Sıfırıncı Gn Zafiyeti - Yazılım reticisinin henz haberdar olmadıęı veya mevcut bir yamasının bulunmadıęı, aktif olarak smrlen gvenlik aıkları) adı verilir. Bir Zero-day saldırısı gerekleřtięinde gvenlik cihazlarında bu saldırıyı tanıyacak bir imza (signature) bulunmaz. Bu ařamada, saldırının aę iinde yatay hareket etmeden (Lateral Movement) nce tespit edilebilmesi tamamen **SOC** (Security Operations Center - Gvenlik Operasyon Merkezi) analistlerinin davranıřsal analiz ve tehdit avcılıęı yeteneklerine baęlıdır.

CVE Ataması ve Zafiyetin Yařam Dngs

Gizli kalmıř bir zafiyet kamuoyuna (public) aıklandıęı anda, MITRE organizasyonu tarafından standartlařtırılmıř bir **CVE** (Common Vulnerabilities and Exposures - Bilinen Zafiyetler ve Etkilenimler) numarası atanır (rn: CVE-2014-6271).

CVE numarasının atanması, siber savařta kronometrenin alıřmaya bařladıęı andır. Bu andan itibaren acımasız bir yarıř bařlar: Tehdit aktrleri yayınlanan teknik detayları kullanarak zafiyeti otomatik olarak smrecek **Exploit** (Zafiyet smr kodu) geliřtirmek iin

yarıřırken; Blue Team (Savunma Takımı) ve IT yöneticileri, sistemleri yamalamak (Patch) için zamanla yarıřır.



Zafiyetlere Müdahale ve Risk Azaltma Stratejileri (Responding to Vulnerabilities)

Bir CVE'ye karşı uygulanabilecek nihai ve kalıcı tek çözüm **Patch** (Yama - yazılım üreticisi tarafından kaynak kodun düzeltilip yayınlandığı resmi güncelleme) uygulamaktır.

Ancak bir Zero-day vakasında veya kurumun operasyonel kesinti (downtime) yaşayamayacağı kritik anlarda resmi yamanın çıkmasını beklemek zorundasınızdır. Bu bekleme süresi, siber güvenliğin en stresli dönemidir ve hayatta kalmak için derhal **Mitigation** (Risk Azaltma / Geçici Çözüm) stratejileri devreye alınmalıdır. Resmi yama beklenirken uygulanması gereken hayati teknik adımlar şunlardır:

1. Ağ Eriřimini Kısıtlamak (Restricting Access): Sistemin dış dünyaya olan maruziyetini (Attack Surface) minimize etmektir. Zafiyet barındıran servise (örneğin bir yönetim paneline veya veritabanı portuna) herkesin erişmesini engellemek için Güvenlik Duvarı (Firewall) üzerinde **ACL** (Access Control List - Eriřim Kontrol Listesi) kuralları yazılarak, yalnızca güvenilen (Trusted) IP adreslerinin erişimine izin verilir.

```
# Örnek bir IPTables kuralı ile zafiyet barındıran 8080 portuna (Örn: Apache Tomcat)
# sadece güvendiğimiz 192.168.1.50 IP adresinden gelen erişimlere izin veriyoruz.
sudo iptables -A INPUT -p tcp -s 192.168.1.50 --dport 8080 -j ACCEPT

# Diğer tüm dış dünyadan gelen 8080 port isteklerini (zafiyeti sömürme ihtimali olanları)
# sessizce düşürüyoruz (DROP). Bu sayede saldırgan, portun açık olduğunu bile tarayamaz.
sudo iptables -A INPUT -p tcp --dport 8080 -j DROP
```

Yukarıdaki komutlar sayesinde, sistem yamalanmamış ve zafiyetli (vulnerable) durumda olsa bile, saldırgan ağ seviyesinde engellendiği için Exploit kodunu hedef sisteme ulaştıramaz.

2. Üreticinin Sağladığı Geçici Önlemleri Uygulamak (Workarounds): Yama hazır olmasa bile üretici genellikle zafiyetin tetiklenmesini engelleyecek yapılandırma değişiklikleri önerir. Bu; zafiyetli bir eklentinin (plugin) devre dışı bırakılması, spesifik bir Windows Registry (Kayıt Defteri) anahtarının değiştirilmesi veya belirli bir servisin tamamen durdurulması olabilir.

3. IPS ve WAF Üzerinde Engelleme (Virtual Patching / Sanal Yamalama): Bu aşama, modern savunma mimarisinin kalbidir. Zafiyet barındıran sistemin önünde duran **IPS** (Intrusion Prevention System - Ağ tabanlı Saldırı Önleme Sistemi) veya **WAF** (Web Application Firewall - Web Uygulama Güvenlik Duvarı) cihazlarına özel kurallar girilir.

DİKKAT: Bu yönetime sektörde **Virtual Patching** (Sanal Yamalama) denir. Sunucu üzerindeki yazılım hala kırılıktır; ancak önündeki WAF veya IPS, gelen ağ paketinin içindeki zararlı yapıyı (Örn: Shellshock saldırısındaki tipik `() { :; };` fonksiyon tanımı kalıbını) derin paket analizi (Deep Packet Inspection) ile tespit eder ve paketi sunucuya ulaşmadan havada yok eder.

```
# Zafiyetli bir Bash kabuğunun (Shellshock) sistemde olup olmadığını tespit etmek için
# kullanılan yerel bir test komutu.
env x='() { :; }; echo "ZAFİYET VAR"' bash -c "echo Test tamamlandı"
```

Bu test komutu çalıştırıldığında çıktı olarak "ZAFİYET VAR" görüyorsak, Bash ortam değişkenlerinin içine yerleştirilmiş olan anonim fonksiyonu (yani zararlı kodu) izinsizce çalıştırıyor demektir. Acilen Bash paketinin güncellenmesi veya ilgili sunucuya giden HTTP Header (User-Agent vb.) girdilerinin WAF üzerinden filtrelenmesi şarttır.

Sistem Yanlış Yapılandırmaları (Misconfigurations)

Zafiyet (Vulnerability) ve Yanlış Yapılandırma (Misconfiguration) Arasındaki Mantıksal Fark

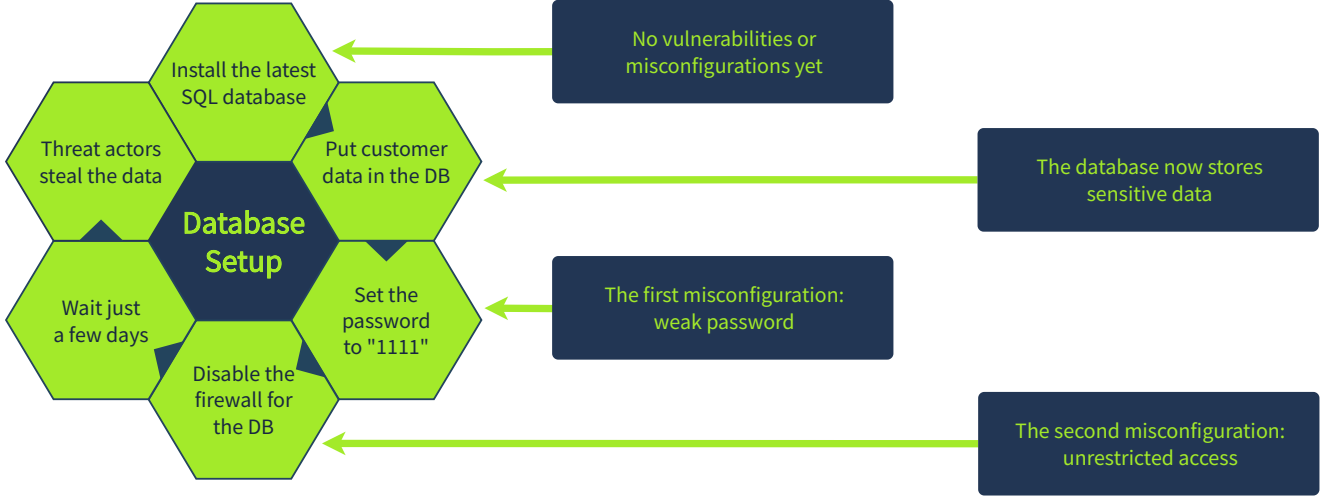
Siber güvenlikte savunma mimarisini inşa ederken, tehditlerin her zaman karmaşık yazılım hatalarından (Örn: Zero-Day veya Buffer Overflow) kaynaklanmadığını anlamak kritik bir öneme sahiptir. Bir yazılım zafiyeti (Bug), kodun yazım aşamasında oluşan ve yamalanması (Patch) gereken yapısal bir kusurdur. Buna karşılık **Misconfiguration** (Yanlış Yapılandırma), tamamen kusursuz ve güvenli olarak tasarlanmış bir yazılımın veya sistemin, BT (Bilgi Teknolojileri) veya sistem yöneticileri tarafından ağa entegre edilirken hatalı, eksik veya varsayılan (Default) ayarlarıyla bırakılması durumudur.

Bu tür hataların temelinde genellikle güvenlik ile kullanılabilirlik (Convenience) arasındaki ters orantı yatar. Sistem yöneticileri, operasyonel süreçleri hızlandırmak veya karmaşık yetkilendirme prosedürlerinden kaçınmak için çoğu zaman "1111" veya "admin" gibi zayıf

parolalar kullanmayı, portları dış dünyaya tamamen açmayı veya erişim kontrollerini devre dışı bırakmayı tercih ederler. Saldırganlar için bir sistemi hacklemek amacıyla karmaşık bir **Exploit** (Zafiyet sömürü kodu) yazmaktan çok daha kolayı, yanlış yapılandırılmış bir sistemin açık kapısından meşru bir kullanıcı gibi içeri girmektir.

Gerçek Dünya Senaryolarında Yanlış Yapılandırmaların Yıkıcı Etkileri

Teorik konseptlerin ötesinde, yanlış yapılandırmaların global çapta nasıl felaketlere yol açtığını incelediğimizde karşımıza üç temel operasyonel hata çıkar:



1. Zayıf Parola Politikaları ve Veri İhlalleri: McDonald's iş başvuruları sisteminde yaşanan ve 64 milyon kullanıcının mesajlaşma verilerini ifşa eden olay, "123456" gibi tahmin edilmesi saniyeler süren parolaların sistemde kabul edilmesinden kaynaklanmıştır. Bu durum, sistemde bir **Password Complexity** (Parola Karmaşıklığı) politikasının zorunlu kılınmaması ve **MFA** (Multi-Factor Authentication - Çok Faktörlü Kimlik Doğrulama) mekanizmasının eksikliğinin doğrudan bir sonucudur.

2. Bulut Altyapısı (Cloud) İzin Hataları: Bulut bilişim, esnekliği artırırken konfigürasyon yüzeyini de genişletir. 106 milyon banka müşterisinin verisinin sızdırıldığı **AWS** (Amazon Web Services) vakası, tipik bir bulut yanlış yapılandırma örneğidir. Genellikle bu tür ihlaller, depolama birimlerinin (Örn: AWS S3 Buckets) internete tamamen açık bırakılmasıyla gerçekleşir.

Aşağıda, bir BT çalışanının "sistem çalışsın yeter" mantığıyla yazdığı ve tüm internetin veritabanı yedeğine erişmesine olanak tanıyan hatalı bir AWS S3 Bucket kuralı (Policy) örneği bulunmaktadır:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": "*",
      "Action": "s3:GetObject",
```

```
"Resource": "arn:aws:s3:::banka-gizli-musteri-verileri/*"  
  }  
]  
}
```

Yukarıdaki konfigürasyon dosyasında yer alan `"Principal": "*" parametresi`, bu veri deposuna erişim için hiçbir kimlik doğrulaması gerektmediğini, internetteki `"Herhangi Birinin"` (Yıldız karakteri tümü anlamındadır) `"Action": "s3:GetObject"` yetkisiyle dosyaları indirebileceğini gösterir. Saldırganın burada bir sistemi kırmasına gerek yoktur; sadece doğru URL'ye gitmesi yeterlidir.

3. IoT (Nesnelerin İnterneti) ve Sessiz Botnet'ler: Yanlış yapılandırılmış akıllı buzdolapları, kameralar veya yönlendiriciler (Router), fabrikadan çıktıkları **Default Credentials** (Varsayılan Kimlik Bilgileri, örn: admin/admin) ile internete bağlandıklarında saniyeler içinde otonom tarayıcılar tarafından tespit edilirler. Tehdit aktörleri bu cihazlara bağlanarak içlerine zararlı yazılım yükler ve bu cihazları geniş çaplı bir **Botnet** (Zombi cihaz ağı) ordusuna dönüştürürler. Bu buzdolapları, ev sahibinin haberi dahi olmadan, kritik kamu kurumlarına devasa boyutlarda **DDoS** (Dağıtık Hizmet Aksatma) saldırıları düzenlemek için kullanılır.

BT Ekipleri Tarafından Güvenli Sistemlere Zafiyet Enjekte Edilmesi

Bir sistemin tasarımı ne kadar güvenli olursa olsun, entegrasyonu yapan ekibin bilgisizliği sistemi anında savunmasız hale getirebilir. Özellikle veritabanı sunucularının yapılandırılmasında bu durum sıklıkla görülür. Kurum içindeki bir web uygulamasının bağlanması gereken kritik bir veritabanı (Örn: MySQL veya PostgreSQL), sadece yerel ağdan (Localhost) erişilebilir olması gerekirken, yanlış yapılandırma sonucu tüm internete (0.0.0.0) açılabilir.

```
# /etc/mysql/mysql.conf.d/mysqld.cnf dosyasındaki hatalı yapılandırma  
[mysqld]  
# Güvenli Olmayan Yapılandırma:  
bind-address = 0.0.0.0  
# Güvenli Olması Gereken Yapılandırma:  
# bind-address = 127.0.0.1
```

Yukarıdaki `bind-address = 0.0.0.0` direktifi, MySQL veritabanının 3306 numaralı port üzerinden dünyanın her yerinden gelen bağlantı isteklerini dinlemesine neden olur. Eğer veri tabanı yöneticisi zayıf bir parola belirlediyse (ki genellikle "root" kullanıcısı parolasız bırakılır), saldırgan doğrudan veritabanına bağlanıp tüm tabloları indirebilir (Data Exfiltration) veya silebilir.

DİKKAT: Bir sistem yöneticisinin güvenlik duvarı (Firewall) üzerinde geçici bir sorun gidermek (Troubleshooting) amacıyla oluşturduğu "Tüm trafiğe izin ver (Any to Any - Allow)" kuralını işlem bittikten sonra silmeyi unutması, siber güvenlik dünyasındaki en yaygın ve en ölümcül yanlış yapılandırma senaryolarından biridir.

Yanlış Yapılandırmalara Müdahale ve Proaktif Savunma Stratejileri (Responding to Misconfigurations)

Yazılım zafiyetlerinin aksine, yanlış yapılandırmaları çözmek için bir donanım veya yazılım güncellemesine (Update/Patch) ihtiyaç yoktur. İhtiyaç duyulan tek şey, sistemi en iyi güvenlik pratiklerine (Best Practices) göre yeniden düzenlemektir.

Bir **SOC** (Security Operations Center - Güvenlik Operasyon Merkezi) analisti olarak, bu tür hataları genellikle bir saldırgan bunları sömürdükten (Exploitation) sonra, ağ trafik loglarındaki anormalliklerden veya yetkisiz erişim denemelerinden (Örn: Aynı IP'den gelen yüzlerce başarısız SSH giriş denemesi) tespit edersiniz. Ancak, güvenlik duruşunu olgunlaştırmak için reaktif (olay sonrası) değil, proaktif (olay öncesi) bir yaklaşım benimsenmelidir:

- **Penetration Testing (Sızma Testi):** Kurum dışından bağımsız, etik hacker'ların (Red Team) işe alınarak, gerçek bir saldırgan perspektifiyle sistemlere saldırmasının simüle edilmesidir. Amaç, otomatik araçların bulamayacağı, ağ mimarisindeki ve yetkilendirmelerdeki mantıksal yanlış yapılandırmaları tespit edip raporlamaktır.
- **Vulnerability Scans (Zafiyet Taramaları):** Ağdaki aktif cihazların tespit edilmesi (Discovery) ve bu cihazlarda açık unutulmuş portların, güncel olmayan servislerin veya değiştirilmemiş varsayılan parolaların otomatik zafiyet tarama araçları (Örn: Nessus, OpenVAS) ile periyodik olarak kontrol edilmesidir.
- **Configuration Audits (Yapılandırma Denetimleri):** Sistemlerin, uluslararası otoriteler tarafından belirlenmiş güvenlik standartlarına (Örn: **CIS Benchmarks** - Center for Internet Security tarafından sağlanan, işletim sistemleri ve bulut yapıları için en sıkı yapılandırma rehberleri) uygunluğunun manuel veya otomatik betikler (Script) aracılığıyla satır satır incelenmesidir.

ÖNEMLİ: Yanlış yapılandırmalar siber güvenliğin "görünmez tehlikesi"dir. Teknik olarak en gelişmiş tespit sistemlerine (IDS/IPS, EDR) sahip olsanız bile, eğer bir kapıyı bilerek açık bıraktıysanız (Misconfiguration), güvenlik ürünleriniz o kapıdan giren kişiyi bir saldırgan değil, yetkili bir kullanıcı olarak değerlendirecek ve hiçbir alarm üretmeyecektir.